個人情報漏えい 机上訓練 参加者配布資料

訓練で扱った論点の解説と、押さえておきたい法令の要点

参加者へ配布可 ／ 訓練終了後　実施日 2026-10-02（金）15:00 - 16:00　株式会社STANDS

配布タイミング: 訓練終了後
シナリオ: 管理画面の**ログインレポートCSVダウンロード機能**の不具合により、顧客が自分でダウンロードしたCSVに他社プロダクトのデータが混入していた

お疲れさまでした。訓練で扱った論点の解説と、押さえておきたい法令の要点をまとめています。
今日決められなかったことは、これから作る対応フローに反映します。

1. シナリオの全体像

時点	起きたこと
第一報	取引先A社から「管理画面からダウンロードした**ログインレポート**のCSVに、弊社のユーザーではないデータが含まれている」と連絡
原因判明	**ログインレポート**の**集計クエリでプロダクトIDの絞り込みが一部効いていなかった。**先月のリリースから入っていた不具合。CSVは約48,000行
規模判明	混入は他社プロダクト**3件分・ユニークユーザー1,240名。**含まれるのは氏名・ユーザーID・uuid・IPアドレス・ユーザーエージェント・リファラ（閲覧画面）・カスタムクエリ・所属企業名など。**同じ期間に同じレポートを取得した顧客は計5社**
二次拡散	A社が社内共有フォルダに保存しており、**10名程度が閲覧可能な状態**だった。ダウンロード有無は確認中

> **この資料での呼び方**: 情報が漏えいした当人（今回は3社のエンドユーザー1,240名）を**「該当者」**と呼びます。個人情報保護法では**「本人」**と呼ばれており、法令や委員会への報告様式ではそちらの表記が使われます。

現実に起こりうる形にしています。**顧客が自分で操作してデータを取得できる機能**であること、**不具合はリリースを通じて全顧客に配られている**ことが、このシナリオの肝です。
一人のミスではなく、**気づかないうちに全顧客が同じ地雷を踏める状態になっていた**という構図です。

2. 各場面の論点と、正解に近い動き

場面① 第一報を受けたとき

論点	正解に近い動き
これはインシデントか、問い合わせか	**「漏えいの疑い」として扱う。** 確証を待たない。誤報でよい
誰に上げるか	一次受けは自分で判断せず、**即座にISMS管理者（藤原さん）へ。**技術的な確認より先
A社に何と返すか	**「そのファイルを削除せず、これ以上共有しないでお待ちください」**
何を記録するか	**受信日時（分単位）**、連絡してきた人、原文そのまま
社内はどこで動くか	**専用チャンネルをその場で立てる。** 第一報を受けた人が作ってよい（許可を待たない）

> **やりがちな失敗**: 「すぐ削除してください」と即答してしまう。
> 親切のつもりでも、**何が漏れたかを調べる唯一の証拠が消えます。**
> 削除は、こちらで中身を特定し、削除証明の取り方を決めてから依頼します。

場面② 原因を調べるとき

論点	正解に近い動き
誰が調査するか	改修した本人を一人にしない。**必ず2名以上。**本人は事実を出す役、別の人が確認する役
止血	**不具合は今この瞬間も生きている。** ダウンロード機能を止めるかを最初に判断する。誰が決めるかを含めて
本番環境の扱い	調査のための操作もログに残る。**触る前に、何のために何を見るかを宣言してから触る**
保全すべき証跡	**管理画面のダウンロード操作ログ**（誰がいつ何を取得したか） / 該当リリースのデプロイ記録 / 集計クエリの変更履歴 / A社が取得したCSVの現物 / 該当期間のDBログ
範囲の確定	**いつから不具合が入っていたか**と、**その間に誰がダウンロードしたか**の2つが揃って初めて件数が出る

> **やりがちな失敗**: 指摘してきた1社の件だけを見て終わる。
> **プロダクトの不具合は、リリース以降のすべての利用者が対象になり得ます。**
> ダウンロードの操作ログが残っていなければ、**範囲を確定できないまま報告することになります。**

場面③ 規模と中身が判明したとき（最重要）

論点	正解に近い動き
件数の数え方	**行数ではなく「該当者の数」**（法律上の「本人の数」）。48,000行ではなく **1,240名**
何が漏れたかの特定	**カスタムクエリは顧客が任意に埋める列。**メールアドレスや社員番号を入れている顧客がいれば、漏れた項目は当社の想定を超える。**まず中身を確認する**
取引先名の露出	ユーザーグループ名には**顧客企業名**が入る。個人情報ではないが、他社に見えた時点で取引先の存在が漏れている（守秘義務）
報告義務	1,000人超に該当する可能性が高い。**「報告対象になり得る」前提で動き始める**
報告主体	**契約上の立て付けで変わる**（次章参照）。まず契約書を確認する
該当者への通知	**当社は該当者の連絡先（メールアドレス）を持っていない。**氏名とIDだけ。**通知は3社経由でしか成立しない。**誰がいつ依頼するかを決める
3社への連絡	**最優先。** 他ルートで知られると信頼の毀損が桁違いに大きくなる

> **やりがちな失敗**:「1,000人以下だから報告義務なし」で止まる。
> 法律上の報告義務がなくても、**委託契約・NDA・SLA上の通知義務は別に存在します。**
> 「法的義務なし ＝ 何もしなくていい」ではありません。

場面④ 二次拡散が判明したとき

論点	正解に近い動き
削除の確認方法	口頭・チャットの「消しました」では不十分。**書面（メール可）で、削除日時・対象・確認者を残してもらう**
ダウンロード有無	A社側のログで確認可能か依頼する。確認できない場合は**「確認できなかった」と記録する**（曖昧にしない）
「知った時」の起点	法定期限の起算点。**組織として一つに決めて記録する**

---

3. 押さえておきたい法令の要点

> 以下は訓練用の整理です。**実際の判断は必ず法務／顧問弁護士に確認してください。**

個人情報保護委員会への報告義務

個人情報保護法では、以下の**いずれか**に当たる漏えい等（**そのおそれを含む**）が発生した場合、
個人情報保護委員会への報告義務が生じます。

#	類型	今回のシナリオ
1	要配慮個人情報が含まれる	該当しない
2	不正に利用されると財産的被害が生じるおそれがある（クレジットカード番号等）	該当しない
3	不正の目的をもって行われたおそれがある（不正アクセス・ランサムウェア等）	該当しない（過失による誤抽出のため）
4	**該当者（法律上の「本人」）の数が1,000人を超える**	**該当する可能性が高い（1,240名）**

重要な点が2つあります。

- **「おそれ」で足りる。** 漏えいが確定していなくても、疑いの段階で報告対象になり得ます。
  だからこそ初動は「確証を待たずに動く」が正しいのです。
- **数えるのは該当者の数。** レコード数ではありません。

報告の期限

種別	期限
速報	「知った時」から**速やかに**（概ね3〜5日以内）
確報	「知った時」から**30日以内**（上表の類型3「不正の目的」の場合は60日以内）

「知った時」がすべての起点です。だから訓練で時刻の記録にこだわりました。
第一報を受けた時刻を残していないと、期限の計算ができません。

該当者への通知

該当者（法律上の「本人」）への通知も原則として必要です。
通知が困難な場合は、該当者の権利利益を保護するために
必要な代替措置（公表など）を講じることで代えられます。

委託を受けている場合の扱い（今回いちばん重要な論点）

当社が3社から個人データの取扱いの委託を受けている立場なのか、
当社が自ら取得した個人情報なのかで、報告主体が変わります。

立て付け	報告主体
当社が3社から**委託を受けて**取り扱っている	委託元である3社が報告義務を負う。**当社は3社へ通知することで、当社自身の報告義務が免除され得る**
当社が**自ら取得した**個人情報	**当社が報告主体**

この整理は、事故が起きてから契約書を探していては間に合いません。
速報は「知った時」から数日以内です。その時間を契約書の確認に使うことになります。

今日この場で答えが出たかどうかにかかわらず、確かめたいのは次の2点です。

問い	なぜ
誰でも答えられる状態か	特定の人が知っているだけなら、その人が不在の日には答えが出ない
どこを見れば分かるか言えるか	「調べれば分かる」と「すぐ出せる」は別物。置き場所が決まっているかどうか

> **アクション**: 契約上の立て付けを整理し、すぐ参照できる場所に置く。
> 「どの顧客との契約が、どちらの類型か」の一覧が必要です。

---

4. 誤送信・誤抽出インシデントでやりがちな失敗

#	失敗	なぜ起きるか
1	**良かれと思って即座に削除を依頼する**	相手を待たせたくない心理。結果として証拠が消える
2	**確証を得てから報告しようとする**	「まだ確実じゃないので」。初動が数日遅れる
3	**当事者が一人で調べて一人で抱える**	責められると思うから。**当社は無罰ルールです**
4	**レコード数を漏えい件数として報告してしまう**	直感的に行数を数えてしまう。数えるのは該当者の数
5	**時刻を記録していない**	対応に必死で記録が後回しになる。法定期限の起点が失われる
6	**指摘してきた1社だけ見て、他の利用者を確認しない**	不具合はリリースを通じて全顧客に配られている
7	**顧客との共有チャンネルで社内調整を始めてしまう**	全員リモートでSlackが主戦場。Slack Connectでは相手に全部見える
8	**重要な判断をDMで決めてしまう**	リモートでは自然な動き。しかし記録が残らず、後から追えない

---

5. 明日から全員にお願いしたい5つのこと

① 「疑い」の段階で上げてください

確証は要りません。「なんかおかしい気がする」で構いません。
誤報を許容します。 遅れることのほうがはるかに高くつきます。

② 時刻をメモしてください

「何時何分に、誰から、何を聞いたか」。スクリーンショットでもSlackのリンクでも構いません。
これが法定報告の起点になります。

③ インシデント専用のチャンネルを立てて、そこに集めてください

今回の訓練では専用チャンネルが作られず、やり取りが
顧客との共有チャンネル・既存の社内チャンネル・DM・スレッドに分散しました。

これは誰かの判断ミスではありません。**「作る」という決まりが無かっただけ**です。
ただ、そのままだと実際のインシデントで次のことが起きます。

分散すると起きること	なぜ困るか
全体像を持っている人がいなくなる	誰が何を知っているかがバラバラになり、二重連絡や矛盾した回答が出る
あとから時系列を再構成できない	「知った時」や経緯の説明は、**散らばった履歴をかき集めて作ることになります**
顧客との共有チャンネルに社内の相談が流れる	Slack Connect では**相手に全部見えています**
関係ない人を巻き込む／必要な人が入らない	既存チャンネルでは、対象者を絞れません

お願いしたいこと

- **第一報を受けた人が、その場で専用チャンネルを立てる。** 許可を待つ必要はありません
- 名前は `incident-{日付}-{短い件名}` のように、ひと目でそれと分かるものにする
- 調査・判断・対外文面の検討は、**すべてそこに集約する**
- 顧客との共有チャンネルは、**顧客への連絡だけ**に使う
- **迷ったら作ってください。** 空振りでも、あとでアーカイブすれば済みます

④ 重要なやり取りは、DMではなくチャンネルに残してください

全員リモートなので、つい個別のDMで話が進みます。しかし**DMで決まった判断は記録に残らず、
後から「誰がいつ何を決めたか」を追えません。** 法定報告や監査の場面でこれが致命傷になります。

- ハドルや通話で決めたことは、**必ずSlackに書き戻す**
- DMを使うときは、**先にチャンネルへ「〇〇さんにDMします」と書く**

⑤ 隠さないでください

当社は無罰ルールです。 誤送信や誤抽出をした本人を責めません。
隠されることのほうが、会社にとって圧倒的に危険だからです。
早く言うほど被害が小さくなります。それだけです。

---

6. この訓練の後に実施すること

1. 今日出た「決められなかったこと」を統合し、**対応フローの目次**にします
   - 少なくとも**専用チャンネルの命名規則と、誰が立てるか**はフローに明記します（今回、作られなかったため）
2. 各項目に責任者と期限を割り当てます
3. 技術面の点検（集計クエリのプロダクト絞り込みのテスト整備・リリース前チェック・ダウンロード操作ログの保全）を、エンジニアチームのタスクとして別途起票します
   - **今回の不具合は架空のものです。** 実際に起きた事象ではありません。
   ただし**同じことが起こり得る箇所**なので、未然の点検として扱います

4. 対応フローのドラフトができたら、**関係者のレビューで確認します**（訓練の再実施はしません）
   - 今日詰まった箇所が、ドラフトを読めば解消されるかを机上で確かめます
